



FILE PATH TRASVERSAL, TRAVERSAL SEQUENCES BLOCKED WITH ABSOLUTE PATH BYPASS

ROAD TO HALL OF FAME



BRYHAN EDUARDO GUZMAN MARTINEZ

178508

SEGURIDAD INFORMÁTICA

Índice

MARCO TEÓRICO Y FUNDAMENTACIÓN TÉCNICA	2
Concepto de File Path Traversal y Bypass de Filtros	2
Relación con OWASP, CIA y Principios de Defensa	2
PROCEDIMIENTO PASO A PASO Y USO DE BURP SUITE	2
EXPLICACIÓN TÉCNICA DEL PAYLOAD	3
Evidencias y Capturas de Pantalla	4
MITIGACIÓN RECOMENDADA	8

MARCO TEÓRICO Y FUNDAMENTACIÓN TÉCNICA

Concepto de File Path Traversal y Bypass de Filtros

El *Path Traversal* (o *Directory Traversal*) permite a un atacante leer archivos arbitrarios en el servidor que ejecuta la aplicación. Esto puede incluir código fuente, datos de configuración, archivos de credenciales o archivos críticos del sistema operativo como `/etc/passwd` en entornos Linux.

Muchos mecanismos de defensa intentan sanear las entradas eliminando o bloqueando secuencias comunes de salto de directorio (`../`). Si la validación se limita exclusivamente a buscar la presencia de secuencias relativas (`../`) pero no restringe las rutas absolutas que inician desde el directorio raíz (`/`), la aplicación sigue siendo vulnerable cuando el backend permite abrir archivos usando rutas absolutas directas.

Relación con OWASP, CIA y Principios de Defensa

- **OWASP Top 10:** Se clasifica dentro de la categoría **A01:2021 – Broken Access Control** (Control de Acceso Deficiente), ya que la aplicación no restringe el acceso de lectura únicamente a la carpeta pública de imágenes.
- **Tríada de Seguridad (CIA):**
 - **Confidencialidad:** Se ve gravemente comprometida al exponer archivos sensibles del sistema operativo a usuarios no autorizados.
 - **Integridad y Disponibilidad:** Aunque esta vulnerabilidad es primariamente de lectura, en ciertos escenarios la lectura de archivos clave (como claves SSH, archivos de configuración o credenciales de base de datos) puede derivar en la toma de control total del servidor.
- **Principio de Mínimo Privilegio:** El servidor web debe ejecutarse con una cuenta de usuario con permisos estrictamente acotados, impidiendo que el proceso pueda leer archivos del sistema como `/etc/passwd`.

PROCEDIMIENTO PASO A PASO Y USO DE BURP SUITE

1. Configuración e inicio de Burp Suite:

- Se inicia Burp Suite Community Edition seleccionando la opción *"Temporary project in memory"* y dando clic en *"Next"*.
- Se selecciona la configuración por defecto (*"Use Burp defaults"*) y se presiona *"Start Burp"*.

2. Activación del Proxy e Intercepción:

- En la pestaña superior se navega hacia la sección **Proxy**.
- Se verifica que el botón de intercepción esté activo (*"Intercept is on"*) y se da clic en *"Open browser"* para abrir el navegador integrado de Burp Suite.

3. Navegación a la aplicación web:

- En el navegador de Burp, se ingresa la URL asignada a la instancia del laboratorio.

4. Captura del tráfico HTTP:

- Al cargar la página principal con imágenes de productos, las solicitudes de carga de archivos de imagen son interceptadas en el Proxy de Burp Suite.
- Se reenvían (*Forward*) las peticiones iniciales hasta identificar la solicitud GET enfocada en la carga de imágenes:

HTTP

GET /image?filename=66.jpg HTTP/2

Host: 0a8e0022046a43bf80d13f3300000076.web-security-academy.net

5. Análisis y Modificación de la Petición (Repeater):

- Se selecciona la petición GET /image?filename=66.jpg y se envía al módulo **Repeater** (mediante *Right Click* -> *Send to Repeater* o combinación Ctrl + R).
- Dentro de Repeater, se modifica el parámetro filename en la línea de solicitud sustituyendo 66.jpg por la ruta absoluta del archivo objetivo:

HTTP

GET /image?filename=/etc/passwd HTTP/2

- Se hace clic en el botón **Send** para enviar la petición modificada al servidor.

6. Confirmación del Explotación exitosa:

- El servidor responde con un código de estado HTTP/2 200 OK.
- En el cuerpo de la respuesta (*Response*) se despliega exitosamente el contenido del archivo /etc/passwd mostrando las cuentas de usuario del sistema (ej. root:x:0:0:root:/root:/bin/bash).
- Al regresar a la interfaz del laboratorio en el navegador, la aplicación confirma la resolución del reto indicando el estado **Solved**.

EXPLICACIÓN TÉCNICA DEL PAYLOAD

- **Payload utilizado:** /etc/passwd
- **Mecanismo de funcionamiento:** La aplicación web filtra o bloquea las secuencias de escape del tipo `../`. Sin embargo, la función del lado del servidor encargada de leer el archivo de la imagen (como `file_get_contents()` o un equivalente en el código fuente) toma el valor entregado en el parámetro `filename` y lo evalúa de forma directa. Al proporcionar una ruta absoluta que comienza con la barra diagonal inicial (/), la ruta se resuelve desde la raíz del sistema de archivos del servidor Linux, ignorando el directorio base donde se almacenan habitualmente las imágenes y permitiendo la lectura del archivo `/etc/passwd`.

Evidencias y Capturas de Pantalla

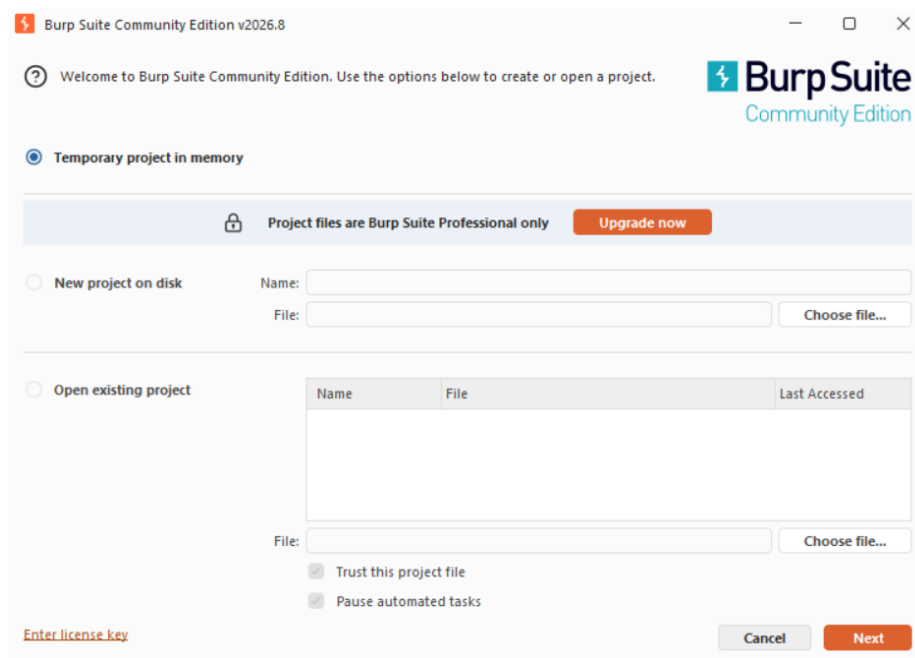


Imagen 1. Abrimos BurpSuit previamente descargado, seleccionamos “Temporary Project in memory”, después demos click en “Next”

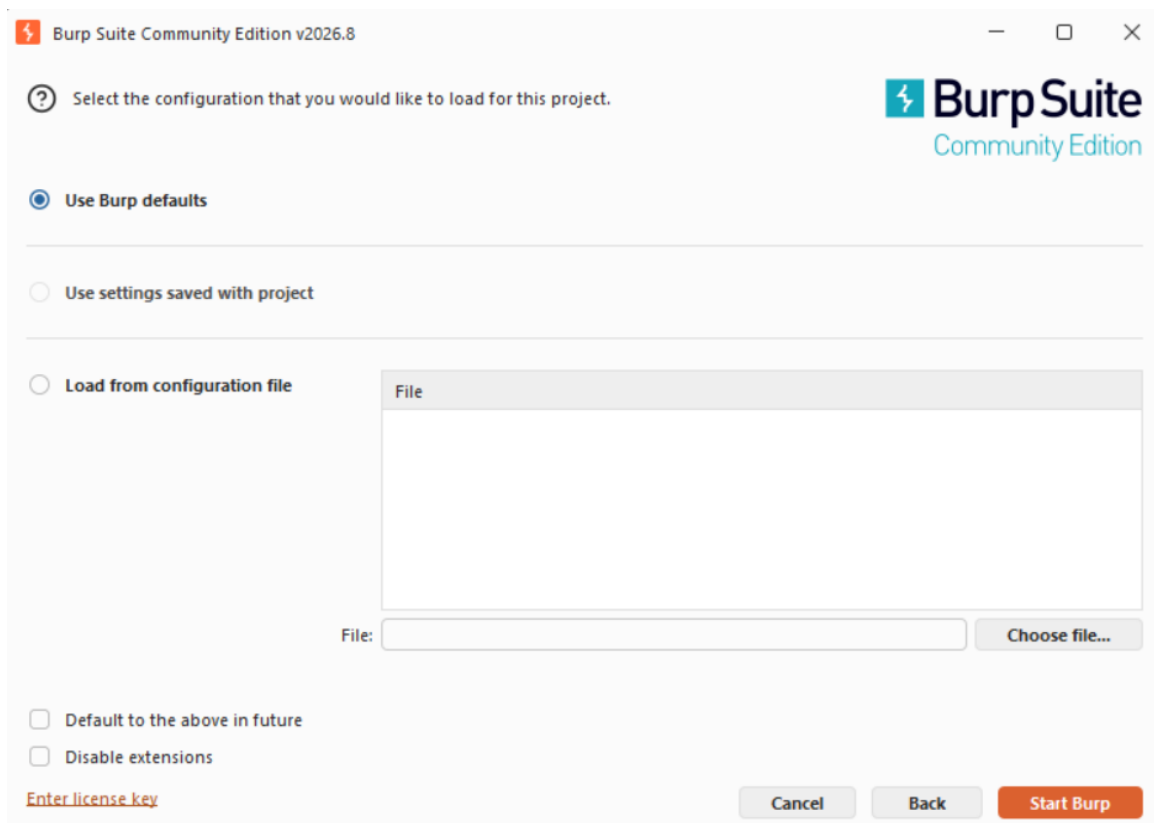


Imagen 2. Seleccionamos “Use Burp defaults” y damos click en “Start Burp”.

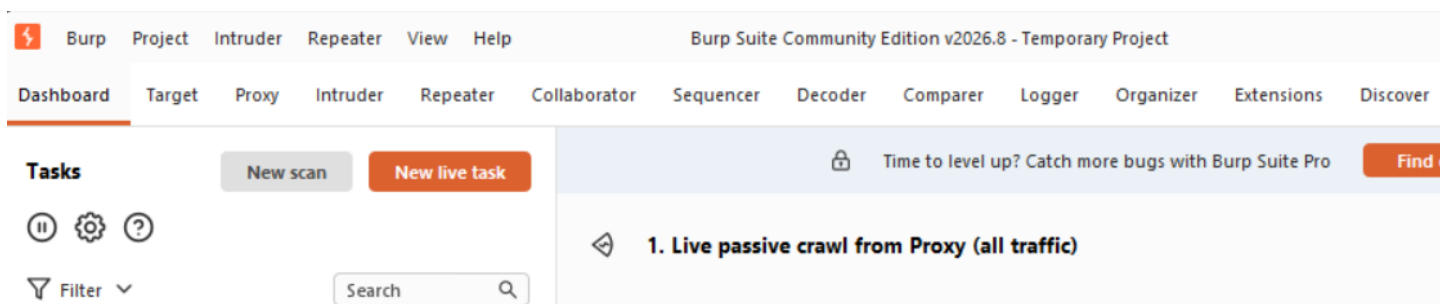


Imagen 3. El las pesañas que están arriba, daremos click en “Proxy”

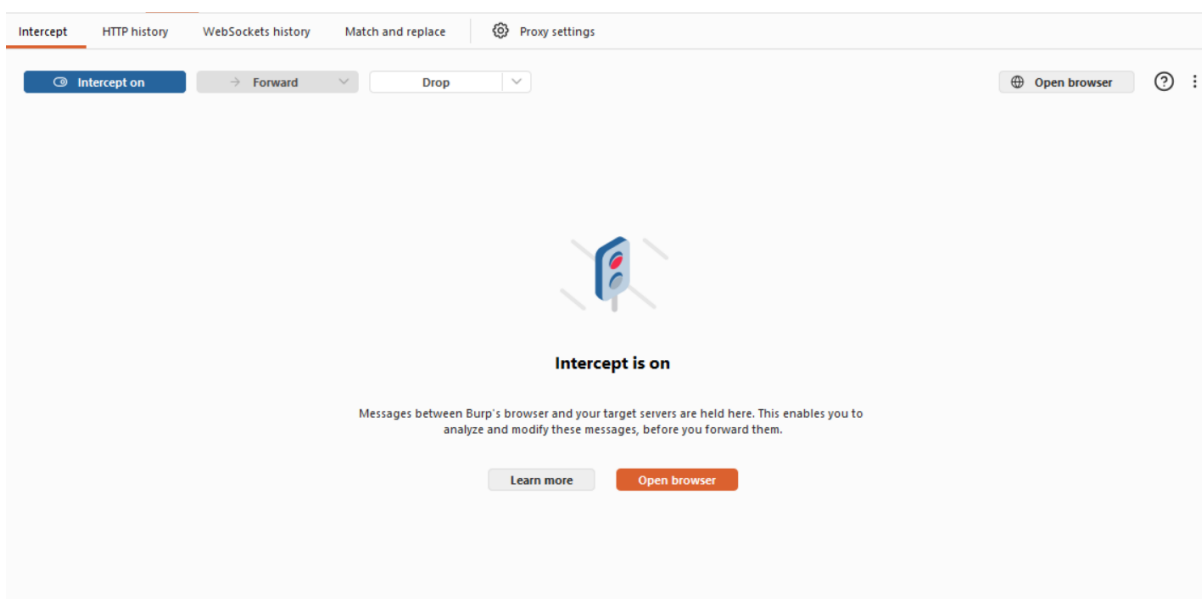


Imagen 4. Daremos click en “Intercept off” para que cambie a “Intercept on” después daremos click en open browser.



Imagen 5. Se abrirá una pestaña del navegador donde pegaremos la URL que nos dieron cuando accedimos al laboratorio

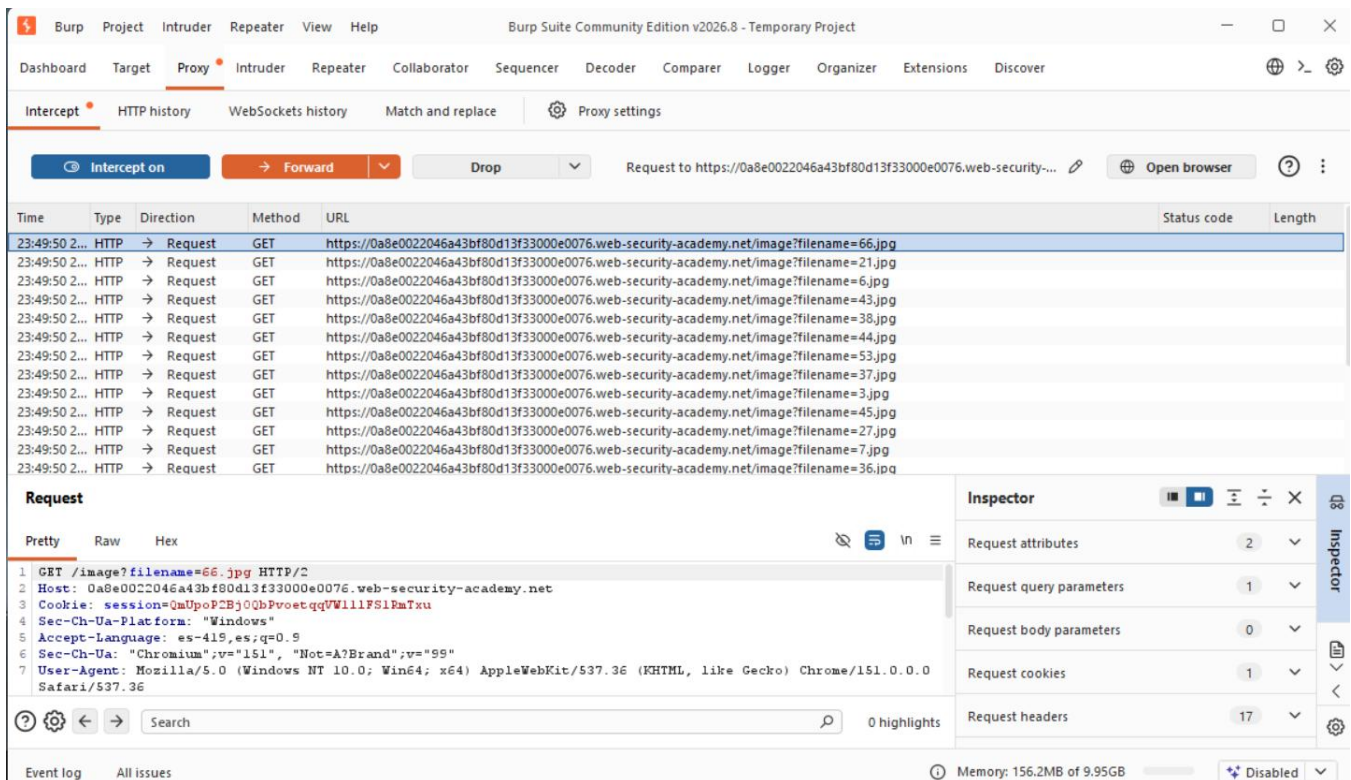


Imagen 6. En BurpSuite nos aparecerá un archivo HTTP, donde presionaremos “FOWARD” después se abrirán más archivos, el que ocuparemos será el que dice “GET /image?filename=66.jpg”.

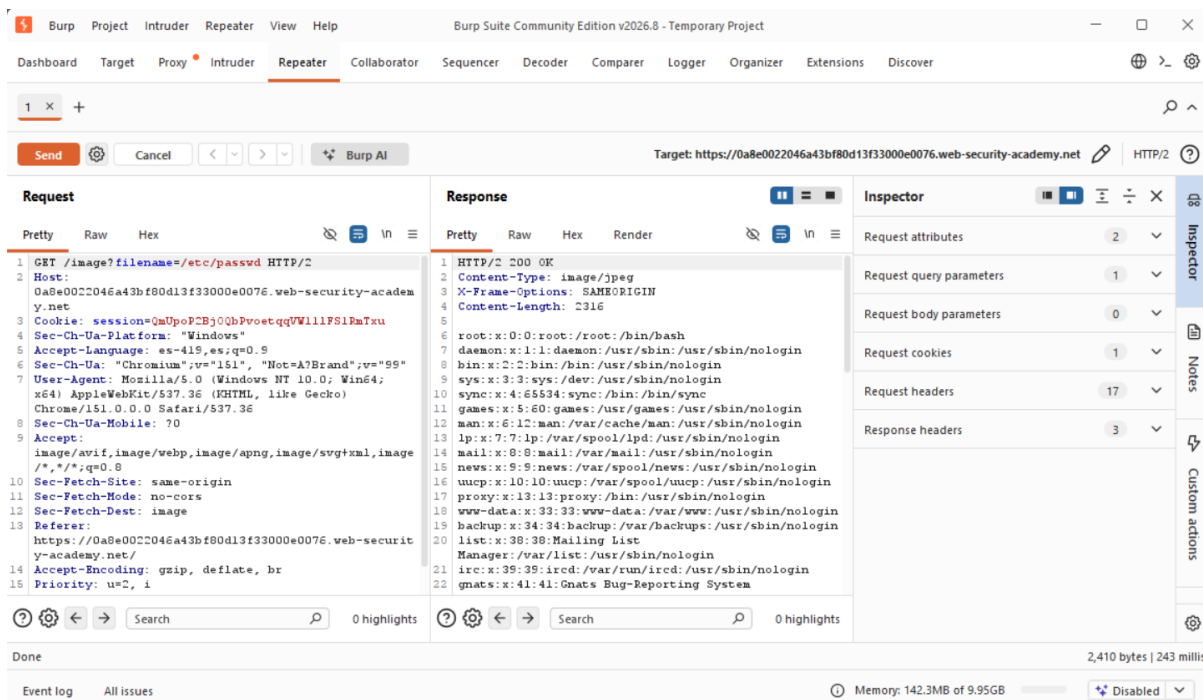


Imagen 7. El cual seleccionaremos daremos click y pondremos la opción “Send to Repeater” cambiaremos el nombre de la ruta de “GET /image?filename=66.jpg” por “GET /image?filename= /etc/passwd” y daremos click en “Send”.

```
1 HTTP/2 200 OK
2 Content-Type: image/jpeg
3 X-Frame-Options: SAMEORIGIN
4 Content-Length: 2316
5
6 root:x:0:0:root:/root:/bin/bash
7 daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
8 bin:x:2:2:bin:/bin:/usr/sbin/nologin
9 sys:x:3:3:sys:/dev:/usr/sbin/nologin
10 sync:x:4:65534:sync:/bin:/bin/sync
11 games:x:5:60:games:/usr/games:/usr/sbin/nologin
12 man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
13 lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
14 mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
15 news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
16 uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
17 proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
18 www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
19 backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
20 list:x:38:38:Mailing List
   Manager:/var/list:/usr/sbin/nologin
21 irc:x:39:39:ircd:/var/run/ircd:/usr/sbin/nologin
22 gnats:x:41:41:Gnats Bug-Reporting System
```

Imagen 8. Una vez que se envió aparecerá que todo esta bien con un “200 OK” y con toda la información por la cual hicimos el ataque.

Lab: File path traversal, traversal sequences blocked with absolute path bypass

PRACTITIONER



LAB



Solved



This lab contains a path traversal vulnerability in the display of product images.

The application blocks traversal sequences but treats the supplied filename as being relative to a default working directory.

To solve the lab, retrieve the contents of the `/etc/passwd` file.



ACCESS THE LAB



Solution



Community solutions



Imagen 9. En la página del laboratorio aparecerá que ya esta resuelto ese laboratorio (Solved √)

MITIGACIÓN RECOMENDADA

Para corregir esta vulnerabilidad y prevenir ataques de *Path Traversal*, se deben implementar las siguientes buenas prácticas en el código de la aplicación y la infraestructura:

1. Evitar la transmisión directa de rutas o nombres de archivo:

No permitir que los usuarios especifiquen nombres de archivos o rutas en los parámetros HTTP. En su lugar, utilice identificadores o un índice numérico (por ejemplo, id=12), resolviendo la imagen correspondiente mediante una tabla o mapa interno seguro.

2. Validación estricta con lista blanca (Whitelisting):

Si es imprescindible recibir nombres de archivo, valide la entrada contra una lista blanca que contenga únicamente caracteres alfanuméricos permitidos o nombres de archivo predefinidos.

3. Canonización y verificación de rutas de acceso:

Antes de abrir cualquier archivo, utilice funciones del sistema de archivos para obtener la ruta absoluta canónica (por ejemplo, `realpath()` en PHP) y verifique explícitamente que la ruta resultante comience dentro del directorio público autorizados para imágenes:

PHP

```
$base_dir = '/var/www/images/';  
  
$filepath = realpath($base_dir . $_GET['filename']);  
  
if ($filepath === false || strpos($filepath, $base_dir) !== 0) {  
  
    // Acceso denegado  
  
}
```

4. Principio de Mínimo Privilegio:

Asegurar que el proceso del servicio web (por ejemplo, `www-data` o `nobody`) se ejecute con los permisos mínimos indispensables en el sistema operativo, restringiendo el acceso de lectura a directorios sensibles del sistema como `/etc/` o `/var/log/`.